

Cyber Security Exam Master Notes (20/80 Strategy)

Based on class slides and *Computer Security: Principles and Practice (3rd Edition)*. These notes focus on the most exam-relevant 20% concepts that produce 80% of the results.

1. Malicious Software (Malware)

High-Yield Concepts (20% for 80% Results)

- Malware is software designed to compromise confidentiality, integrity, or availability.
- Major malware types: Virus, Worm, Trojan Horse, Spyware, Rootkit, Bot.
- Virus needs a host file; worm spreads independently across networks.
- APT (Advanced Persistent Threat) targets organizations using stealth and persistence.
- Virus phases: Dormant, Triggering, Propagation, Execution.
- Macro viruses infect documents and scripts instead of executable files.
- Countermeasures: Antivirus, firewalls, patching, user awareness, backups.

Solved Important Questions

Question	Answer
Differentiate Virus and Worm.	Virus requires a host program and spreads when the host runs. Worm is standalone and spreads automatically over networks.
What is an APT?	APT is a long-term, stealthy cyberattack usually conducted by skilled attackers or state-sponsored groups.

2. Denial of Service (DoS) Attacks

High-Yield Concepts (20% for 80% Results)

- DoS attacks affect availability of services.
- Main targets: Network bandwidth, system resources, application resources.
- Common attacks: SYN flood, ICMP flood, UDP flood, HTTP flood.
- DDoS uses many compromised systems (botnets).
- Reflection and amplification attacks use spoofed addresses.
- Defense methods: filtering, anti-spoofing, IDS/IPS, rate limiting, load balancing.

Solved Important Questions

Question	Answer
What is SYN Flooding?	Attacker sends many TCP SYN requests without completing handshake, exhausting server resources.
Difference between DoS and DDoS.	DoS uses one source system; DDoS uses many distributed systems called botnets.

3. Intrusion Detection

High-Yield Concepts (20% for 80% Results)

- Intrusion is unauthorized access or misuse of systems.
- Types of intruders: Cybercriminals, hacktivists, state-sponsored attackers.
- IDS monitors systems or networks for suspicious activity.
- Host-based IDS monitors a single system.
- Network-based IDS monitors network traffic.
- Intrusion lifecycle: Reconnaissance → Access → Privilege escalation → Maintain access → Cover tracks.

Solved Important Questions

Question	Answer
What is IDS?	Intrusion Detection System detects malicious or suspicious activities in systems or networks.
Difference between HIDS and NIDS.	HIDS works on host machines; NIDS monitors network traffic.

4. Firewalls and Intrusion Prevention Systems

High-Yield Concepts (20% for 80% Results)

- Firewall controls incoming and outgoing network traffic.
- Packet filtering firewall checks packet headers.
- Stateful firewall tracks active connections.
- Application-level gateway filters application traffic.
- IPS actively blocks attacks while IDS mainly detects them.
- Unified Threat Management combines firewall, IDS/IPS, antivirus.

Solved Important Questions

Question	Answer
What is a firewall?	A firewall is a security system that filters network traffic based on security rules.
Difference between IDS and IPS.	IDS detects attacks and alerts; IPS detects and automatically blocks attacks.

5. Operating System Security

High-Yield Concepts (20% for 80% Results)

- OS security protects system resources and data.
- Hardening removes unnecessary services and vulnerabilities.
- Security maintenance includes patching and updates.

- Linux security uses permissions and access control.
- Windows security includes authentication, ACLs, and Defender.
- Virtualization security isolates virtual machines.

Solved Important Questions

Question	Answer
What is OS hardening?	Process of securing an operating system by reducing vulnerabilities and disabling unnecessary services.
Why are patches important?	Patches fix vulnerabilities that attackers may exploit.

6. Cloud and IoT Security

High-Yield Concepts (20% for 80% Results)

- Cloud computing provides shared computing resources over the Internet.
- Cloud risks include data breaches, insecure APIs, insider threats.
- Security controls include encryption, IAM, backups, MFA.
- IoT devices are vulnerable due to weak passwords and limited security.
- Botnets like Mirai exploited insecure IoT devices.

Solved Important Questions

Question	Answer
What are major cloud security risks?	Data breaches, insecure APIs, account hijacking, insider threats.
Why is IoT security difficult?	IoT devices have limited resources, weak authentication, and poor update mechanisms.

7. Internet Authentication

High-Yield Concepts (20% for 80% Results)

- Authentication verifies user identity.
- Kerberos provides ticket-based authentication.
- X.509 certificates support public key infrastructure.
- PKI manages digital certificates and public keys.
- Multi-factor authentication improves security.

Solved Important Questions

Question	Answer
What is Kerberos?	Kerberos is a network authentication protocol using tickets and symmetric cryptography.
What is PKI?	Public Key Infrastructure manages certificates and public/private keys.

8. Wireless Network Security

High-Yield Concepts (20% for 80% Results)

- Wireless networks are vulnerable because communication occurs over radio waves.
- WEP is insecure due to weak encryption.
- WPA2 and WPA3 provide stronger wireless security.
- 802.11i improves authentication and encryption.
- Mobile device security is essential in BYOD environments.

Solved Important Questions

Question	Answer
Why is WEP insecure?	WEP uses weak encryption and vulnerable key management.
What is WPA2?	WPA2 is a wireless security standard using AES encryption.

Final Exam Revision Strategy

- Focus first on definitions and differences (Virus vs Worm, IDS vs IPS, DoS vs DDoS).
- Prepare architecture diagrams: TCP handshake, DDoS architecture, Firewall placement.
- Memorize common attacks and defenses.
- Practice review questions from the book chapters.
- Write concise answers with keywords for theory exams.

Prepared from class slides and textbook chapters on Malware, DoS, IDS, Firewalls, OS Security, Cloud & IoT Security, Internet Authentication, and Wireless Security.